

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5110 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I SAIRAM D 192424111 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: SAIRAM D

Annexure A

Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

Identify which traffic requires AH, ESP, or both

Design packet flow with appropriate IPsec modes (transport/tunnel)

Justify protocol selection for different data types

Evaluate performance vs security trade-offs

Problem Analysis

A multinational enterprise is deploying IPsec to protect communication between its branch offices over the public Internet. Since the Internet is an untrusted network, the organization needs protection against unauthorized access, data modification, data interception, and replay attacks.

IPsec provides two main security protocols: Authentication Header (AH) and Encapsulating Security Payload (ESP).

AH provides authentication, integrity, and anti-replay protection, but it does not provide confidentiality. ESP provides confidentiality through encryption and can also provide integrity, authentication, and anti-replay protection.

For most enterprise VPN deployments, ESP is preferred because it can provide both confidentiality and integrity.

Task 1: Identify Which Traffic Requires AH, ESP, or Both

Confidential business data such as financial transactions, customer information, database communication, and internal application traffic should use ESP because this information requires confidentiality as well as integrity and authentication.

Financial transactions should use ESP with encryption and integrity protection because sensitive financial information must not be visible to attackers on the public Internet.

Database communication should also use ESP because database queries and responses may contain confidential business and customer information.

Voice and video conferencing traffic should use ESP because business discussions and meetings may contain sensitive information that should not be intercepted.

For traffic where confidentiality is not required but authentication and integrity are important, AH can be considered. AH ensures that the packet has not been modified and that it originated from an authenticated source.

Using both AH and ESP is technically possible, but it is generally unnecessary in a modern enterprise network because ESP can already provide encryption, integrity, authentication, and anti-replay protection.

Therefore, the recommended approach is to use ESP for most enterprise traffic and use AH only when there is a specific requirement for integrity and authentication without confidentiality.

Task 2: Design Packet Flow with Appropriate IPSec Modes

For communication between branch offices, IPSec Tunnel Mode is the most suitable option.

The packet flow can be represented as:

Branch A Computer

↓

Branch A IPSec Gateway

↓

ESP Tunnel through Public Internet



Branch B IPSec Gateway



Branch B Computer

The original packet before IPSec contains the following:

Original IP Header + TCP/UDP Header + Application Data

When ESP Tunnel Mode is applied, a new IP header is added and the original IP packet is protected inside the tunnel.

The resulting packet can be represented as:

New IP Header + ESP Header + Encrypted Original IP Packet + ESP Authentication Data

The original IP packet is encrypted, so users on the public Internet cannot see the internal communication between the two branch networks.

For example, Branch A may use the network 10.1.0.0/24 and Branch B may use 10.2.0.0/24.

The communication would be:

Branch A Network



IPSec Gateway A



Encrypted IPSec Tunnel



IPSec Gateway B



Branch B Network

Tunnel Mode is preferred because it protects the complete original IP packet and is specifically suitable for site-to-site VPN communication.

Transport Mode is mainly suitable for host-to-host communication. In Transport Mode, the original IP header remains visible while the upper-layer information is protected.

For example:

Original IP Header + ESP Header + Encrypted TCP/UDP Data

Therefore, Transport Mode can be used when individual hosts directly support IPSec, while Tunnel Mode is preferred for communication between branch-office networks.

Task 3: Justify Protocol Selection for Different Data Types

Financial information requires strong confidentiality and integrity. Therefore, ESP with encryption and integrity protection should be used.

Database traffic should also use ESP because it can contain confidential customer and organizational information.

Voice and video communication should use ESP to prevent unauthorized users from monitoring the communication.

For non-sensitive traffic where only integrity and authentication are required, AH may be used.

However, using ESP with both encryption and integrity protection provides a more consistent and secure solution for an enterprise VPN.

Therefore, the general recommendation is: ESP + Tunnel Mode for branch-to-branch communication.

AH should only be used when confidentiality is not required and there is a specific requirement for AH.

Task 4: Evaluate Performance versus Security Trade-offs

Using encryption and authentication increases security but also introduces some processing overhead.

ESP encryption requires CPU resources for encryption and decryption. Integrity checking also requires additional processing. IPSec headers add some additional network overhead.

AH has lower processing requirements because it does not encrypt the data. However, it does not provide confidentiality.

ESP provides stronger overall protection because it provides confidentiality along with integrity and authentication.

The performance impact can be reduced by using hardware cryptographic acceleration, efficient cryptographic algorithms, and modern VPN gateways.

The organization should monitor CPU utilization, bandwidth usage, latency, and packet loss to ensure that the security configuration does not negatively affect business applications.

Therefore, the recommended solution is to use ESP Tunnel Mode for sensitive enterprise communication even though it has slightly higher processing overhead because the security benefits are much greater.

2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

Analyze current SA lifecycle issues

Design an automated key management mechanism (e.g., IKE-based)

Propose a strategy for key renewal and revocation

Evaluate scalability and fault tolerance

Problem Analysis

The organization is experiencing frequent IPSec key management problems, including expired keys, mismatched keys, failed VPN connections, and manual configuration errors.

An IPSec Security Association (SA) contains important information such as encryption algorithms, integrity algorithms, keys, Security Parameter Index (SPI), lifetime, and other security parameters.

If the SA information is manually configured, managing hundreds or thousands of branch offices becomes difficult.

For example, if one gateway changes its key while the other gateway continues using the old key, the IPSec communication can fail.

Therefore, the organization needs an automated key management mechanism.

Task 1: Analyze Current SA Lifecycle Issues

The normal SA lifecycle consists of SA creation, establishment, active communication, rekeying, expiration, and deletion.

The lifecycle can be represented as:

SA Creation



SA Establishment



Active Communication



SA Rekeying



Old SA Expiration



SA Deletion

Problems can occur when the SA expires before a new SA is created.

Another problem occurs when the two VPN gateways have different keys or security parameters.

For example:

Gateway A uses New Key



Gateway B uses Old Key



Authentication Failure

↓

VPN Communication Failure

Manual SA management also increases the possibility of configuration mistakes.

Therefore, automatic SA management is required for a large enterprise.

Task 2: Design an Automated Key Management Mechanism Using IKE

The recommended solution is to use Internet Key Exchange version 2 (IKEv2).

IKEv2 automatically performs authentication, negotiates security parameters, establishes keys, and creates IPSec Security Associations.

A simplified IKEv2 process is:

Gateway A

↓

IKE_SA_INIT

↓

Gateway B

↓

Authentication

↓

Child SA Creation

↓

IPSec Communication

IKEv2 creates a secure management connection between the two gateways and negotiates the parameters required for IPSec communication.

The enterprise should use strong authentication, such as certificate-based authentication, to authenticate branch gateways.

Once authentication is completed, IKEv2 automatically generates and manages the cryptographic keys required by the IPSec connection.

This eliminates the need for administrators to manually configure and distribute individual IPSec keys.

Task 3: Strategy for Key Renewal and Revocation

Keys should not be used indefinitely.

The organization should configure automatic rekeying before the existing SA reaches its lifetime.

For example:

SA Created



Normal Communication



Approaching SA Expiration



Automatic IKEv2 Rekey



New Keys Generated

↓

New SA Established

↓

Old SA Removed

The new SA should be established before the old SA expires. This provides a short overlap period and prevents communication interruptions.

If a key or gateway is compromised, the affected SA should be immediately terminated.

The compromised device credentials or certificate should also be revoked.

The process should be:

Compromise Detected

↓

Identify Affected Gateway

↓

Terminate Existing SA

↓

Revoke Credentials or Certificate

↓

Generate New Keys

↓

Establish New IKEv2 SA

↓

Resume Secure Communication

Certificate-based authentication with a centralized Public Key Infrastructure (PKI) can help manage authentication and certificate revocation across a large organization.

Task 4: Evaluate Scalability and Fault Tolerance

Manual key management may work for a small number of branches, but it becomes difficult when an organization has hundreds or thousands of branches.

IKEv2 provides scalability because each gateway can automatically authenticate its peer, negotiate security parameters, generate keys, establish Security Associations, and perform rekeying.

This reduces administrative work and minimizes configuration errors.

For fault tolerance, the organization should deploy redundant IPSec gateways.

The architecture can be:

Internet



Primary VPN Gateway

Backup VPN Gateway



Enterprise Network

If the primary VPN gateway fails, the backup gateway can take over and establish new IKEv2 and IPSec Security Associations.

The organization should also use multiple Internet connections, automated health monitoring, centralized configuration management, logging, and automatic SA re-establishment.

These mechanisms ensure that the VPN service continues operating even when a gateway or network connection fails.

Overall Recommended Solution

For secure branch-to-branch communication, the organization should use ESP in Tunnel Mode because it provides confidentiality, integrity, authentication, and anti-replay protection.

AH can be used when only authentication and integrity are required without confidentiality, but it is not normally necessary when ESP already provides these features.

For key management, IKEv2 should be used to automatically negotiate and manage IPSec Security Associations.

Automatic rekeying should be configured before SA expiration to prevent communication failures caused by expired keys.

Certificate-based authentication and centralized PKI should be used for large-scale authentication and certificate revocation.

Redundant VPN gateways, multiple Internet connections, health monitoring, and automatic SA re-establishment should be implemented to provide fault tolerance.

Therefore, the final enterprise solution is:

- ESP Tunnel Mode
- IKEv2
- Automatic SA Management
- Automatic Key Renewal
- Certificate-Based Authentication
- Key/Credential Revocation
- Redundant VPN Gateways

This solution provides a secure, scalable, reliable, and manageable IPSec infrastructure for multinational enterprise communication.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation